

MegaTravel Threat Modeling Lab

Assignments B & D

B. Assets

The following sensitive assets were identified based on attacker motivation, business requirements, and applicable regulations (GDPR, PCI DSS).

Asset	Exposure	Security Goals	Impact of Compromise
Customer PII (names, emails, passports, addresses)	Web app, backend, database, support staff	Confidentiality (primary), Integrity	GDPR fines, lawsuits, mass data breach, reputation damage
Payment data (card numbers, transactions)	Payment module, payment gateway, DB (tokenized)	Confidentiality, Integrity	Financial losses, PCI DSS fines, criminal liability
Booking records (flights, hotels, itineraries)	Backend, database, external provider APIs, employees	Integrity (primary), Availability	Incorrect bookings, customer loss, direct revenue loss
User credentials (passwords, tokens, session data)	Auth service, database (hashed)	Confidentiality, Integrity	Account takeover, fraudulent bookings, identity theft
Business data (analytics, pricing, strategies)	Internal systems, dashboards, management	Confidentiality	Competitive advantage loss, market damage
Employee data (HR records, salaries, contracts)	HR systems, admins, managers	Confidentiality, Integrity	GDPR fines, internal conflicts, legal action
Infrastructure config (API keys, certs, server configs)	DevOps, CI/CD, config stores	Confidentiality, Integrity	Full system compromise, data exfiltration
Audit logs (access logs, transaction logs)	SIEM systems, administrators	Integrity, Availability	Cannot investigate incidents, attackers hide their tracks

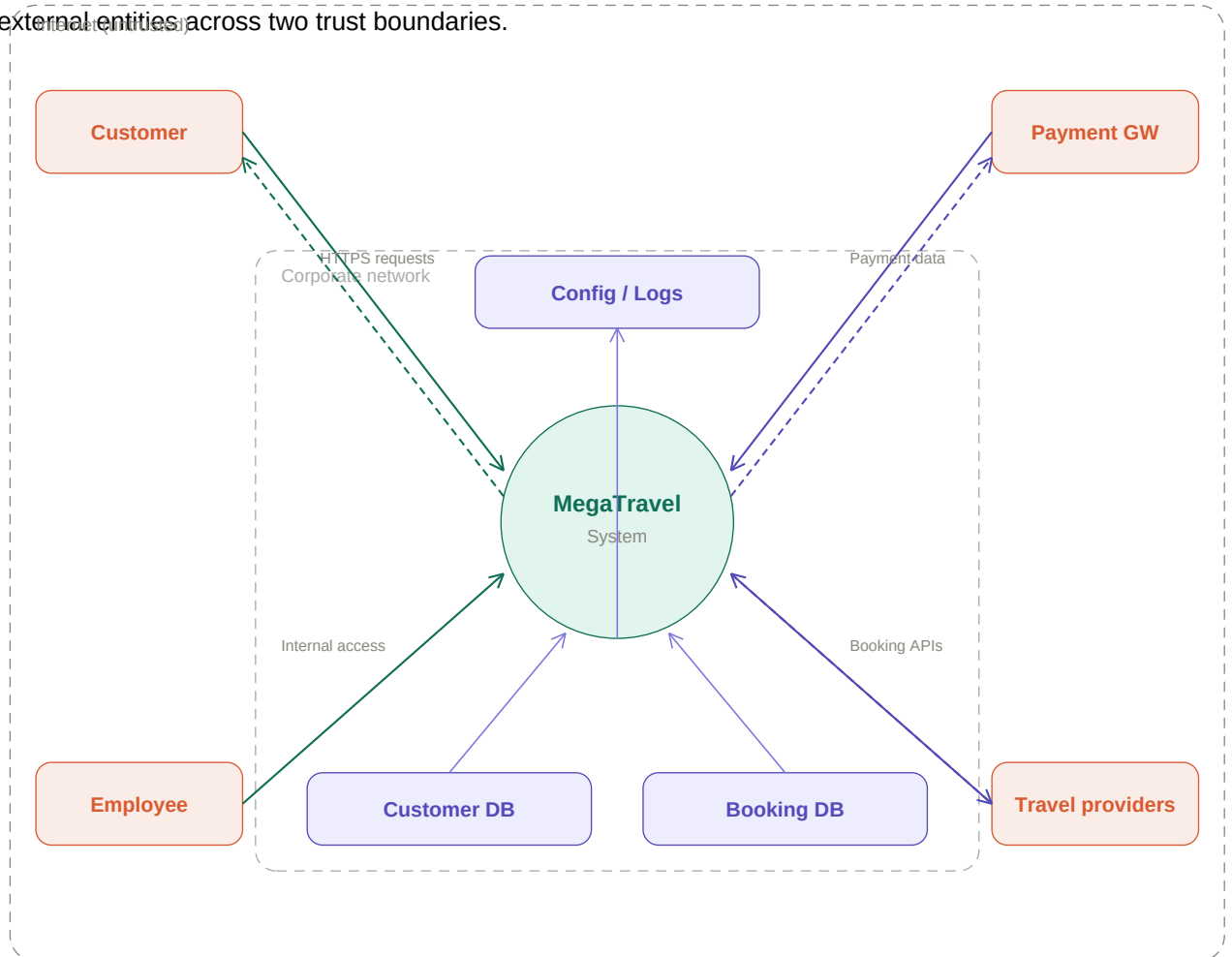
Key Regulations:

- **GDPR** – applies to all EU customer and employee data; fines up to 4% of global revenue
- **PCI DSS** – mandatory for payment card data handling; non-compliance leads to fines and loss of processing rights
- **Local data protection laws** – vary by jurisdiction (UK, US, Hong Kong); require data localization and breach notification

D. Data Flow Diagrams

D.1 Context Diagram (Level 0)

The context diagram shows the MegaTravel system as a single process interacting with four external entities across two trust boundaries.



External Entities:

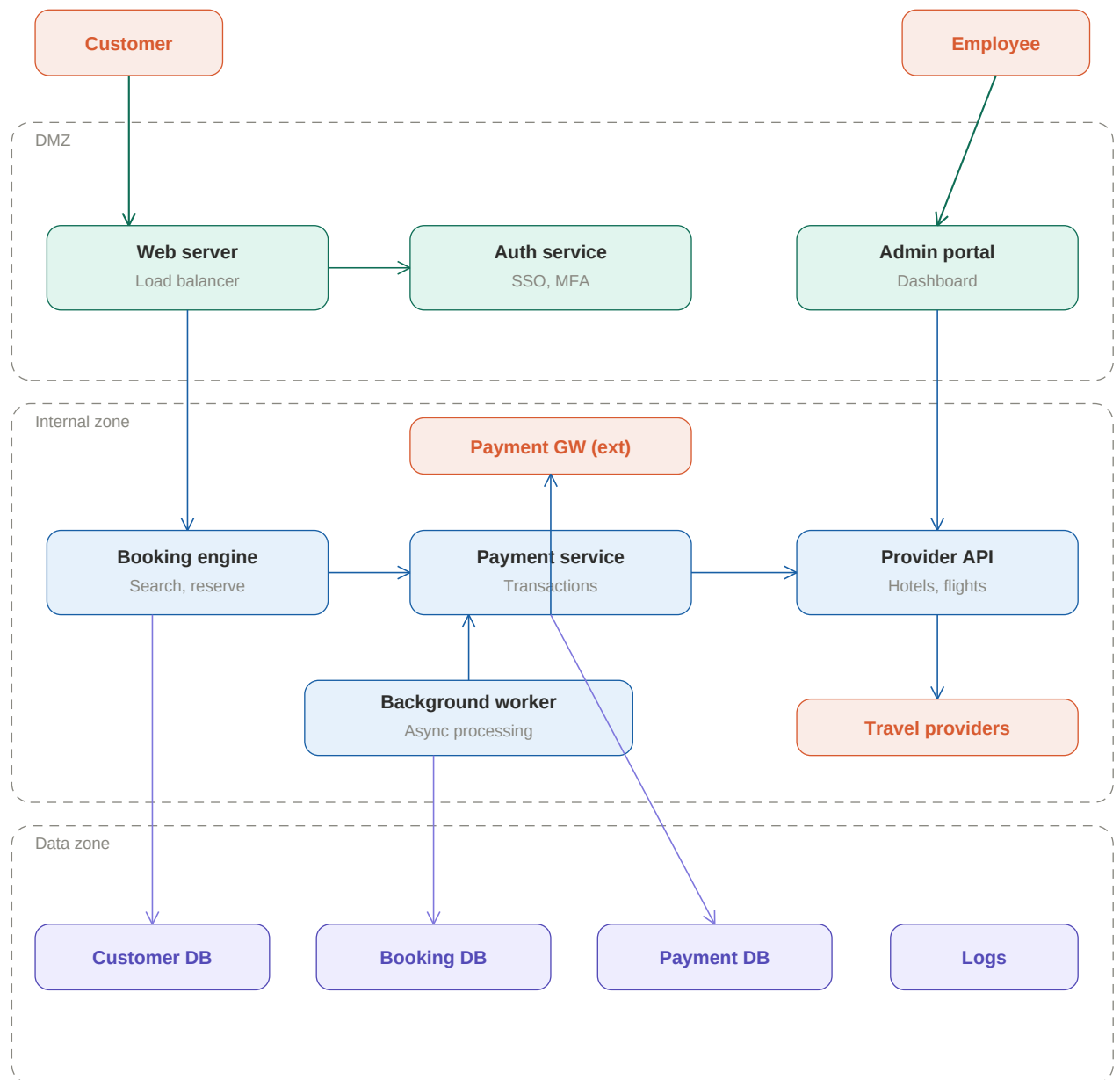
- **Customer** – accesses via web/mobile apps over HTTPS
- **Employee** – accesses internal dashboards and admin tools
- **Payment Gateway** – external payment processing service
- **Travel Providers** – external APIs for hotels, airlines, car rentals

Trust Boundaries:

- **Internet (untrusted)** – all external entities and customer-facing interfaces
- **Corporate network (trusted)** – internal processes and data stores

D.2 Level 1 DFD (Decomposed)

The Level 1 DFD decomposes the central process into sub-processes organized across three trust zones.



Trust Zone	Components	Description
DMZ	Web Server / Load Balancer Auth Service (SSO, MFA) Admin Portal	First line of defense. Validates all incoming requests before forwarding to the internal zone.
Internal Zone	Booking Engine Payment Service Provider API Integration Background Worker	Core business logic. Processes bookings, handles payments, communicates with external travel providers.
Data Zone	Customer DB, Booking DB Payment DB, Logs	Persistent storage. Accessible only via the internal zone service layer. No direct external access.

Key Data Flows:

- Customer → Web Server → Auth Service → Booking Engine → Booking DB
- Booking Engine → Payment Service → Payment Gateway (external)
- Booking Engine → Provider API → Travel Providers (external)

- Employee → Admin Portal → Internal services

Trust Boundary Transitions:

- **Internet** → **DMZ**: authentication required (credentials, MFA tokens)
- **DMZ** → **Internal**: role-based authorization; validated requests only
- **Internal** → **Data**: service-layer access only; parameterized queries